

TechNova Internal Doc

Quy Trình Xử Lý Sự Cố Bảo Mật Thông Tin

Mã tài liệu: SEC-POL-014 **Phiên bản:** 3.2 **Ngày hiệu lực:** 01/03/2026 **Ngày rà soát tiếp theo:** 01/03/2027 **Chủ sở hữu tài liệu:** Phòng An ninh Thông tin (InfoSec) **Phê duyệt:** Giám đốc Công nghệ (CTO) — Trần Minh Khoa **Phạm vi áp dụng:** Toàn bộ nhân viên, cộng tác viên, nhà thầu phụ và đối tác có quyền truy cập vào hệ thống, hạ tầng hoặc dữ liệu của Công ty Cổ phần Công nghệ TechNova ("Công ty") **Mức độ bảo mật tài liệu:** Nội bộ — Hạn chế (Internal — Restricted) **Vai trò được phép truy cập:** employee, it, security, hr

Đây là tài liệu mô phỏng được tạo ra để kiểm thử pipeline RAG nội bộ. Nội dung, tên người, số liệu và sự cố nêu trong tài liệu này là hư cấu, không phản ánh sự kiện có thật.

1. Mục đích

Tài liệu này quy định quy trình chuẩn (SOP) để phát hiện, phân loại, ứng phó, khắc phục và rút kinh nghiệm sau các sự cố an ninh thông tin xảy ra trong phạm vi hệ thống của TechNova, bao gồm nhưng không giới hạn ở: rò rỉ dữ liệu, truy cập trái phép, mã độc, tấn công từ chối dịch vụ (DDoS), lộ thông tin xác thực (credential leak), và các sự cố liên quan đến bên thứ ba (nhà cung cấp, đối tác tích hợp API).

Mục tiêu của quy trình:

- Giảm thiểu thời gian phát hiện (MTTD) và thời gian khắc phục (MTTR) sự cố.
- Đảm bảo tuân thủ nghĩa vụ pháp lý về thông báo vi phạm dữ liệu (bao gồm Nghị định 13/2023/NĐ-CP về bảo vệ dữ liệu cá nhân tại Việt Nam, và các yêu cầu hợp đồng với khách hàng doanh nghiệp thuộc EU theo GDPR khi áp dụng).
- Chuẩn hóa vai trò, trách nhiệm và kênh liên lạc trong tình huống khẩn cấp để tránh nhầm lẫn hoặc chậm trễ.
- Lưu vết đầy đủ phục vụ điều tra nội bộ, kiểm toán và cải tiến liên tục.

2. Phạm vi và định nghĩa

2.1 Phạm vi áp dụng

Quy trình áp dụng cho mọi sự cố ảnh hưởng đến:

- Hệ thống sản xuất (production) và môi trường staging có chứa dữ liệu thật.
- Hạ tầng cloud (AWS ap-southeast-1, GCP asia-southeast1) và các dịch vụ SaaS nội bộ (Slack, Google Workspace, Jira, Notion, Qdrant Cloud, Langfuse Cloud).
- Thiết bị đầu cuối của nhân viên (laptop công ty, điện thoại BYOD có cài MDM).
- Dữ liệu khách hàng, dữ liệu nhân sự, mã nguồn, khóa API và bí mật thương mại.

2.2 Định nghĩa thuật ngữ

Thuật ngữ	Định nghĩa
Sự cố bảo mật (Security Incident)	Bất kỳ sự kiện nào vi phạm hoặc đe dọa vi phạm chính sách bảo mật, tính bảo mật, toàn vẹn hoặc khả dụng của hệ thống/dữ liệu.
IC (Incident Commander)	Người chỉ huy sự cố, chịu trách nhiệm điều phối toàn bộ quá trình ứng phó.
MTTD	Mean Time To Detect — thời gian trung bình từ khi sự cố xảy ra đến khi được phát hiện.
MTTR	Mean Time To Respond/Recover — thời gian trung bình từ khi phát hiện đến khi khắc phục xong.
IOC	Indicator of Compromise — dấu hiệu cho thấy hệ thống đã bị xâm nhập (IP lạ, hash file độc hại, log bất thường).

War room	Kênh liên lạc tập trung (Slack channel hoặc phòng họp) được mở riêng cho một sự cố cụ thể.
----------	--

3. Phân loại mức độ nghiêm trọng (Severity Levels)

Mức độ nghiêm trọng được xác định bởi người phát hiện đầu tiên hoặc trực ca InfoSec, và có thể được điều chỉnh bởi IC trong quá trình ứng phó.

Mức	Tên gọi	Tiêu chí	SLA phản hồi ban đầu	SLA cập nhật định kỳ	Người phê duyệt escalation
SEV-1	Nghiêm trọng (Critical)	Rò rỉ dữ liệu khách hàng/nhân sự trên diện rộng; hệ thống production ngừng hoạt động toàn bộ; ransomware đang lan; truy cập trái phép đã xác nhận vào hệ thống chứa PII.	15 phút	Mỗi 30 phút	CTO + CEO
SEV-2	Cao (High)	Nghi ngờ truy cập trái phép chưa xác nhận phạm vi; lộ khóa API/secret có khả năng khai thác; một dịch vụ quan trọng bị gián đoạn (ví dụ: API RAG ngừng đáp ứng).	30 phút	Mỗi 1 giờ	Trưởng phòng InfoSec
SEV-3	Trung bình (Medium)	Phát hiện quét cổng (port scanning) bất thường; cảnh báo từ WAF/IDS chưa xác nhận là tấn công thật; vi phạm chính sách nội bộ không gây rò rỉ dữ liệu.	2 giờ	Mỗi 4 giờ	Trưởng ca trực (on-call lead)
SEV-4	Thấp (Low)	Sự kiện đáng ghi nhận nhưng không có tác động ngay (ví dụ: nhân viên báo cáo email giả mạo bị chặn thành công).	1 ngày làm việc	Theo tuần	Kỹ sư trực ca

Lưu ý quan trọng: Khi chưa xác định rõ mức độ, mặc định phân loại ở mức cao hơn (fail-safe cao) và hạ cấp sau khi có đủ bằng chứng, không làm ngược lại.

4. Vai trò và trách nhiệm

Vai trò	Trách nhiệm chính
Người phát hiện (Reporter)	Báo cáo ngay lập tức qua kênh quy định tại Mục 6, không tự ý xử lý hoặc xóa dấu vết.
Trực ca InfoSec (On-call Security Engineer)	Tiếp nhận, xác minh sơ bộ trong SLA quy định, khởi tạo ticket sự cố, đề xuất mức độ nghiêm trọng.
Incident Commander (IC)	Được chỉ định cho SEV-1/SEV-2; điều phối toàn bộ nguồn lực, ra quyết định escalation, là đầu mối duy nhất phát ngôn trong war room.
Kỹ sư khắc phục (Responder)	Thực hiện các bước kỹ thuật: cô lập hệ thống, thu thập bằng chứng, vá lỗ hổng, khôi phục dịch vụ.
Đại diện Pháp chế & Tuân thủ	Đánh giá nghĩa vụ thông báo pháp lý (Nghị định 13/2023/NĐ-CP yêu cầu thông báo cơ quan chức năng trong 72 giờ đối với vi phạm dữ liệu cá nhân quy mô lớn), soạn thảo thông báo cho khách hàng nếu cần.

Đại diện Truyền thông/PR	Soạn thông điệp truyền thông nội bộ và bên ngoài, chỉ được phát ngôn khi có sự đồng ý của CTO/CEO.
HR Business Partner	Tham gia khi sự cố liên quan đến hành vi của nhân viên (nội gián, vi phạm chính sách cổ ý), xử lý theo quy trình kỷ luật lao động.

5. Quy trình 6 bước ứng phó sự cố

Bước 1 — Phát hiện (Detection)

Nguồn phát hiện có thể đến từ: cảnh báo tự động (Datadog, GuardDuty, Langfuse trace bất thường), báo cáo từ nhân viên, báo cáo từ khách hàng qua kênh support@technova.vn, hoặc từ bên thứ ba (nhà nghiên cứu bảo mật báo lỗ hổng qua chương trình Responsible Disclosure).

Hành động bắt buộc: - Ghi lại thời điểm phát hiện chính xác (timestamp UTC+7). - Không tắt máy, không xóa log, không tự sửa cấu hình khi chưa có chỉ đạo từ trực ca InfoSec — việc này có thể phá hủy bằng chứng pháp y (forensic evidence).

Bước 2 — Xác minh và phân loại (Triage)

Trực ca InfoSec xác minh sự cố có thật hay là báo động giả (false positive), thu thập thông tin ban đầu: hệ thống bị ảnh hưởng, phạm vi dữ liệu, vector tấn công nghi ngờ. Tạo ticket trong Jira dự án SEC với template chuẩn, gắn nhãn mức độ nghiêm trọng theo Mục 3.

Bước 3 — Ngăn chặn (Containment)

Chia làm hai giai đoạn:

- Ngăn chặn tức thời (Short-term containment):** cô lập hệ thống bị ảnh hưởng khỏi mạng (network isolation), vô hiệu hóa tài khoản/API key nghi bị lộ, chặn IP nguồn tại WAF/firewall. Mục tiêu: dừng thiệt hại lan rộng trong vòng SLA quy định.
- Ngăn chặn dài hạn (Long-term containment):** triển khai bản vá tạm thời, tăng cường giám sát khu vực bị ảnh hưởng, chuẩn bị môi trường sạch để khôi phục.

Bước 4 — Diệt trừ (Eradication)

Xác định nguyên nhân gốc rễ (root cause), loại bỏ hoàn toàn tác nhân gây hại: xóa mã độc, đóng lỗ hổng đã bị khai thác, thu hồi và cấp lại toàn bộ credential có khả năng bị lộ, rà soát toàn bộ hệ thống liên quan để đảm bảo không còn backdoor.

Bước 5 — Khôi phục (Recovery)

Khôi phục dịch vụ về trạng thái hoạt động bình thường theo thứ tự ưu tiên đã thống nhất trong war room. Giám sát tăng cường trong tối thiểu 72 giờ sau khôi phục để phát hiện dấu hiệu tái phát. Chỉ đóng ticket khi IC xác nhận hệ thống ổn định.

Bước 6 — Hậu kiểm và rút kinh nghiệm (Post-Incident Review)

Trong vòng 5 ngày làm việc sau khi đóng sự cố SEV-1/SEV-2, tổ chức buổi “postmortem không quy trách nhiệm cá nhân” (blameless postmortem), bao gồm:

- Dòng thời gian chi tiết (timeline) của toàn bộ sự cố.
- Phân tích nguyên nhân gốc rễ (5 Whys hoặc Fishbone).
- Danh sách hành động khắc phục (action items) có người phụ trách và deadline cụ thể, theo dõi trong Jira.
- Cập nhật runbook, tài liệu này, hoặc quy trình liên quan nếu phát hiện thiếu sót.

Báo cáo hậu kiểm được lưu tại Notion, khu vực “InfoSec / Postmortems”, quyền xem giới hạn vai trò security và it.

6. Kênh báo cáo sự cố

Kênh	Khi nào sử dụng	Thời gian phản hồi
Slack #sec-incident-hotline	Kênh chính cho mọi mức độ, có bot tự động tạo ticket	Ngay lập tức (giờ hành chính)
Hotline khẩn cấp: 1900-xxxx-88 (giả lập)	SEV-1/SEV-2 ngoài giờ hành chính	15 phút

Email: security@technova.vn	Báo cáo không khẩn cấp, báo cáo từ bên ngoài	Trong ngày làm việc
Cổng Responsible Disclosure: security.technova.vn/report	Nhà nghiên cứu bảo mật độc lập báo lỗ hổng	2 ngày làm việc, có chính sách bug bounty riêng

Chính sách không trừng phạt người báo cáo trung thực (Good-faith reporting): Nhân viên báo cáo nhầm hoặc báo cáo hành vi của chính mình một cách trung thực và kịp thời sẽ không bị xử lý kỷ luật vì hành động báo cáo, kể cả khi sự cố do lỗi của họ gây ra. Việc che giấu sự cố mới là hành vi bị xử lý nghiêm khắc.

7. Nghĩa vụ thông báo pháp lý

Khi sự cố liên quan đến rò rỉ dữ liệu cá nhân:

- Đại diện Pháp chế đánh giá trong vòng 24 giờ kể từ khi xác nhận sự cố xem có thuộc diện phải thông báo Bộ Công an (Cục An ninh mạng) theo Nghị định 13/2023/NĐ-CP hay không (áp dụng khi ảnh hưởng đến dữ liệu cá nhân của công dân Việt Nam ở quy mô đáng kể).
- Nếu khách hàng thuộc EU bị ảnh hưởng, đánh giá nghĩa vụ theo GDPR Điều 33 (thông báo cơ quan giám sát trong 72 giờ) và Điều 34 (thông báo chủ thể dữ liệu nếu rủi ro cao).
- Mọi thông báo ra bên ngoài phải được CTO và Pháp chế phê duyệt trước khi gửi; không cá nhân nào được tự ý liên hệ khách hàng hoặc cơ quan chức năng.

8. Ma trận liên lạc khẩn cấp (giả lập)

Vai trò	Người phụ trách	Kênh liên lạc chính	Kênh dự phòng
CTO	Trần Minh Khoa	Điện thoại di động nội bộ	Slack DM + email
Trưởng phòng InfoSec	Nguyễn Hoàng Anh	Slack #sec-incident-hotline	Điện thoại
Trưởng nhóm Hạ tầng (Infra Lead)	Phạm Quốc Bảo	PagerDuty	Slack
Đại diện Pháp chế	Lê Thị Ngọc Hà	Email + điện thoại	Slack DM
Đại diện Truyền thông	Đỗ Minh Thư	Slack DM	Điện thoại

9. Mẫu biểu ghi nhận sự cố (rút gọn)

Mã sự cố: SEC-INC-YYYYMMDD-###
Thời điểm phát hiện: __:__ ngày __/__/__ (UTC+7)
Người báo cáo: _____
Hệ thống ảnh hưởng: _____
Mô tả ban đầu: _____
Mức độ nghiêm trọng đề xuất: SEV-[1/2/3/4]
IC được chỉ định: _____
Trạng thái: [Mới / Đang xử lý / Đã ngăn chặn / Đã khôi phục / Đóng]

10. Ví dụ tình huống minh họa (hư cấu)

Tình huống A — SEV-2: Ngày 12/01/2026, hệ thống giám sát Langfuse ghi nhận số lượng request bất thường tới API /v1/chat từ một dải IP tại nước ngoài, vượt 40 lần lưu lượng trung bình trong 10 phút. Trục ca InfoSec xác minh đây là hành vi dò quét brute-force API key, đã chặn IP tại WAF trong vòng 12 phút, thu hồi và cấp lại toàn bộ API key nội bộ đang hoạt động. Không phát hiện dữ liệu bị truy xuất trái phép. Đóng sự cố sau 6 giờ, hoàn tất postmortem sau 3 ngày làm việc.

Tình huống B — SEV-4: Nhân viên phòng Kế toán báo cáo nhận được email giả mạo CEO yêu cầu chuyển khoản gấp (BEC — Business Email Compromise). Email đã bị bộ lọc chặn, không có thiệt hại. Sự cố được ghi nhận để cập nhật danh sách domain giả mạo vào bộ lọc và đưa vào chương trình đào tạo nhận thức bảo mật quý tiếp theo.

11. Rà soát và cập nhật tài liệu

Tài liệu này được rà soát tối thiểu mỗi 12 tháng hoặc ngay sau bất kỳ sự cố SEV-1 nào. Mọi thay đổi phải được Trưởng phòng InfoSec và CTO phê duyệt và ghi nhận trong bảng lịch sử phiên bản bên dưới.

Phiên bản	Ngày	Người cập nhật	Mô tả thay đổi
1.0	15/06/2023	Nguyễn Hoàng Anh	Ban hành lần đầu
2.0	20/02/2024	Nguyễn Hoàng Anh	Bổ sung ma trận liên lạc khẩn cấp, cập nhật SLA
3.0	10/09/2025	Phạm Quốc Bảo	Thêm quy trình responsible disclosure, cập nhật tham chiếu Nghị định 13/2023/NĐ-CP
3.2	01/03/2026	Nguyễn Hoàng Anh	Rà soát định kỳ hàng năm, cập nhật ví dụ minh họa

Tài liệu này là dữ liệu thử nghiệm cho hệ thống RAG nội bộ. Không sử dụng cho mục đích vận hành thực tế.